

Information Security Policy — My Cash Pilot

Owner: *Bryan Pham, CEO* · Security contact: info@ahnmedia.com Version 1.0 · Effective 16 September 2026 · Next review 16 March 2027

This is the information security policy for My Cash Pilot, the internal bookkeeping and cash-reporting system operated by AHN Media for its own company accounts. It covers the people who operate it, the data it holds, and the controls that protect that data. It is reviewed every six months and after any security incident.

Every control described here is implemented in the system today. Where a control is a human procedure rather than code, the procedure is stated so it can be followed by someone other than its author.

1. Scope and roles

Systems in scope: the My Cash Pilot application (Next.js, hosted on Vercel), its database (Supabase managed PostgreSQL), and the third-party connections it holds — QuickBooks Online, Plaid, Stripe, Veem, and Anthropic's API for reading bank screenshots.

Data in scope: company bank and card transactions, account balances, supplier and staff payment records, payroll cost data, and the access tokens that reach the providers above. No consumer customer data is held, because the system has no outside users.

Role	Responsibility
Security owner	Owens this policy, approves access, runs the reviews, leads incident response
System operator	Day-to-day operation, dependency updates, deployments
Users	Named AHN Media staff with an account; no shared logins

The security owner and the system operator may be the same person in a company of this size. Where they are, a second named person holds break-glass access so no single person's absence blocks recovery.

2. Access control

- **Named accounts only.** Every user has their own account tied to their work email. Shared or generic logins are not permitted.
- **Two factors, enforced by the database, not just the UI.** Every account requires a password and a TOTP authenticator. Sessions below AAL2 are refused by a PostgreSQL row-level security policy (`requiremfa`), so an unauthenticated or single-factor session reads nothing even if it reaches the database directly.

- **Least privilege.** Row-level security is enabled on every table. The service-role key, which bypasses RLS, exists only in server environment variables and is never sent to a browser.
- **Roles.** Owner, staff and viewer capabilities are checked on the server for every API route; sensitive routes are owner-only.
- **Joiners and leavers.** Access is granted by the security owner when someone joins and revoked the same day they leave, including their authenticator factor and any provider connection they made.
- **Review.** Account list and roles are reviewed every six months alongside this policy.

3. Data protection

- **In transit:** HTTPS everywhere, with HSTS set by the application.
- **At rest:** the database is encrypted at rest by the managed provider. Provider access and refresh tokens are additionally encrypted by the application with AES-256-GCM before they are written, so a database dump alone does not yield a usable banking credential.
- **Key management:** the encryption key and all provider secrets live in the hosting platform's environment variables, are never committed to the repository (enforced by `.gitignore` and a test that fails if a secret file is tracked), and are rotated when a holder leaves or when exposure is suspected.
- **Credentials we never see:** bank login details are entered inside Plaid Link and never reach this application. The same is true of QuickBooks and Stripe credentials, which are exchanged through OAuth.
- **Screenshots:** images imported on the Import page are read and discarded — never written to disk or to the database. Only the reviewed rows are stored. No Plaid, QuickBooks or Stripe data is sent to any AI service.
- **No secondary use:** data is used for AHN Media's own bookkeeping and reporting. It is not sold, not shared with advertisers, and not used to train any model.

4. Retention and deletion

- Imported financial records are retained as the company's accounting records for as long as tax and corporate law require.
- Provider tokens are deleted the moment a connection is disconnected, and the connection is revoked at the provider where the provider offers revocation.
- Error records, which may contain a provider's message, are kept for troubleshooting and pruned on a rolling basis.
- On request, an individual's account and authenticator are deleted; company financial records remain, as they are the company's own books.

5. Secure development

- All changes go through version control with review before merge to `main`.
- Typed end to end; the test suite (unit, integration and runtime probes) runs on every push and pull request. A failing suite blocks the change.
- Secrets never enter the repository; environment files are git-ignored and a test asserts it.
- Input from outside the system — uploads, form bodies, provider responses — is validated against a schema before use. Untrusted text from documents and screenshots is treated as data, never as instructions.
- API routes enforce same-origin checks and per-caller rate limits.
- Security headers (Content-Security-Policy, HSTS, `X-Frame-Options: DENY`) are set by the application for every response.

6. Vulnerability management

- **Dependabot** opens a pull request weekly when a dependency has a fix.
- A **security workflow** runs on every push, every pull request, and every Monday regardless of activity: dependency audit, type check, and the full test suite. High and critical advisories in production dependencies fail the build.
- **Triage targets — the patching SLA**: critical within 7 days, high within 30 days, moderate at the next routine update. A fix that cannot be applied within its window is recorded as an exception with a compensating control and a date.
- **End-of-life software**. At every six-month review, and whenever a major version is proposed, the versions this system runs on — Node.js, Next.js, React, and the managed PostgreSQL release — are checked against their published end-of-life dates. Anything within six months of its end of life is scheduled for upgrade before support ends, because a version that stops receiving security fixes cannot be patched at all, whatever the SLA says. The hosting and database platforms are managed services, so their operating systems and database engines are patched by the provider.
- **Managed hosts, not managed laptops**. There are no self-managed servers: the application runs on Vercel and the database on Supabase, and host-level patching is the provider's responsibility. Staff laptops receive operating system and browser updates automatically and run the platform's built-in endpoint protection; the company does not operate a separate endpoint vulnerability scanner.
- The weekly scheduled run exists because a dependency that was clean when installed can acquire an advisory months later with no commit to trigger a check — which is how this project once ran a framework version carrying two critical remote-code-execution advisories.

7. Logging and monitoring

- Every disconnection, permission change and import is written to an audit log with the actor, the time and the reason.

- Failures of a provider call are recorded with the provider's own error identifiers, so a support ticket can be raised with the provider's reference.
- Alerts about unusual financial activity are delivered to a monitored channel; test and sandbox data is excluded so that real alerts are not buried.

8. Third parties

Providers are limited to those the business actually uses: Supabase (database), Vercel (hosting), Plaid, Intuit QuickBooks, Stripe, Veem, Anthropic, and the alerting channels. Each is a named, established provider with its own published security program. A new provider is added only after the security owner reviews what data it would receive, and it is documented in the privacy policy before any data reaches it.

9. Incident response

1. **Contain.** Revoke the affected credential or connection, and rotate keys.
2. **Assess.** Determine what data was reachable, over what period, by whom.
3. **Notify.** Inform the company owner immediately; notify affected providers — including Plaid, where Plaid data is involved — and any other party required by contract or law, without undue delay.
4. **Recover.** Restore from backup if data was altered or destroyed; verify the restored state against provider records.
5. **Learn.** Write up the cause and the fix, and change the control that allowed it. This policy is reviewed after every incident.

Database backups are maintained by the managed database provider with point-in-time recovery; restores are verified as part of the six-month review.

10. Workstations and people

- Staff devices used to access the system have full-disk encryption, a screen lock, and an up-to-date operating system.
- Passwords are unique per service and stored in a password manager; no credential is shared over chat or email.
- Everyone with access reads this policy when they join and at each revision.

Review log

Date	Version	Reviewer	Change
16 Sep 2026	1.0	Bryan Pham, CEO	First issue